

Anatomia dos Ataques

Objetivo da Aula

Apresentar os principais ataques aos processos, tecnologias e pessoas e sua anatomia, desde a obtenção de informações até a sua concretização, a partir de uma metodologia de ataque.

Apresentação

Os ataques são ações praticadas com intenções maliciosas sobre os ativos de informação. Os objetivos são bastante variados. Alguns têm como instrução infectar ou invadir computadores, seja para danificar seus componentes de hardware ou software, comprometer arquivos, ou até mesmo deixar o computador vulnerável a outros tipos de ataques. Os principais ataques podem ser direcionados a vulnerabilidades do sistema operacional ou infraestrutura da rede, falhas de configuração, vulnerabilidades no código das aplicações ou a pessoas e processos nas organizações.

1. Fases de um Ataque

Os ataques não são ações furtivas ou acidentais, são resultado da aplicação de metodologias muito bem elaboradas e ferramentas sempre atualizadas. De acordo com o EC-Council, responsável por formar e certificar hackers éticos, existem cinco passos básicos que os atacantes utilizam quando querem comprometer um sistema ou uma rede:

- Reconhecimento – nesta fase, o agente de ameaça tenta obter o máximo de informações sobre a vítima antes de iniciar o ataque. Os atores de ameaças usam ferramentas da internet, como **nslookup**, **dig** e **whois**, por exemplo, para determinar o espaço de endereçamento IP atribuído a uma determinada corporação ou entidade. Também podem utilizar algumas técnicas de engenharia social.
- Escaneamento e enumeração – esta fase consiste na descoberta e no mapeamento de sistemas e serviços. Podem usar ferramentas como o **nmap** ou o **zenmap (GUI do nmap)** para fazer a varredura dos endereços IP e das portas e serviços disponíveis.

- Obtenção de acesso – é nesta fase que o ataque efetivamente acontece. O atacante tenta ganhar acesso explorando uma vulnerabilidade do sistema operacional, da rede, ou da aplicação. Para isso ele utiliza ferramentas (exploits).
- Manutenção de acesso – uma vez que o acesso ao sistema-alvo seja obtido, o atacante procura manter o acesso para ações futuras. Para isso, ele pode utilizar exploits como backdoors, rootkits e trojans.
- Evasão – nessa fase, o atacante apaga todos os rastros de suas ações dentro do sistema, utilizando métodos de evasão.



Para Praticar

Faça download no nmap no endereço <https://nmap.org/download> e instale conforme descrito em <https://nmap.org/book/install.html>. Uma vez instalado, execute o zenmap. No campo **target**, inclua o endereço de loopback da sua máquina (127.0.0.1) e pressione o botão **scan**. Acompanhe a saída na aba nmap output e ao término do scan da verifique a aba **ports / hosts** as portas, os protocolos e os serviços descobertos na sua máquina. A saída deverá ser similar a apresentada na figura.

Nmap Output	Ports / Hosts	Topology	Host Details	Scans
Port	Protocol	State	Service	Version
✓ 4242	tcp	open	dicom	
✓ 8042	tcp	open	fs-agent	
✓ 21	tcp	open	ftp	OpenBSD ftpd 6.4 (Linux port 0.17)
✓ 80	tcp	open	http	Apache httpd 2.4.52 ((Ubuntu))
✓ 443	tcp	open	http	Apache httpd 2.4.52 ((Ubuntu))
✓ 22	tcp	open	ssh	OpenSSH 8.9p1 Ubuntu 3ubuntu0.1 (Ubuntu Linux; protocol 2.0)

Para maiores informações no uso do **nmap/zenmap**, pesquise o manual em <https://nmap.org/book/man.html>.

2. Ataques de Obtenção e Manutenção de Acesso

Os ataques de acesso exploram vulnerabilidades conhecidas nos sistemas operacionais, na rede serviços de autenticação ou no código das aplicações.

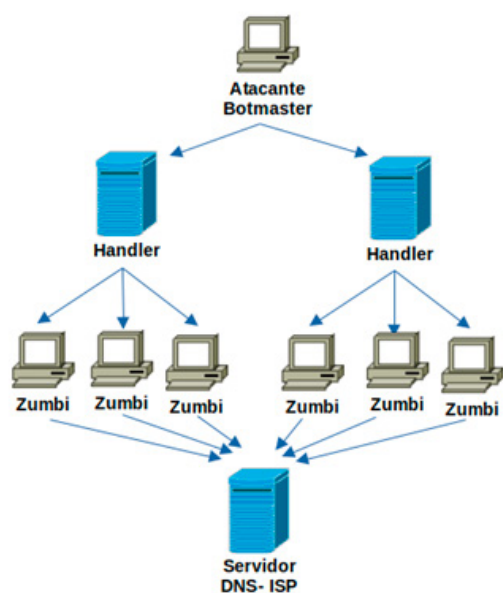
2.1 Ataque de Negação de Serviço

Nos ataques de negação de serviço (DoS – Denial of Service), o atacante utiliza um computador para:

- tirar de operação um serviço ou computador conectado à Internet;
- gerar uma grande sobrecarga no processamento de dados de um computador, de modo que o usuário não consiga utilizá-lo;
- gerar um grande tráfego de dados para uma rede, ocupando toda a banda disponível, de modo que qualquer computador desta rede fique indisponível;
- remover serviços importantes de um provedor, impossibilitando o acesso dos usuários a suas caixas de correio no servidor de e-mail, DNS ou ao servidor Web.

Quando a origem do ataque vem de múltiplos hosts, temos um **DDoS** (Negação de serviços distribuída). A figura 1 apresenta um esquema de um ataque DDoS e seus principais componentes:

Figura 1: Ataque de DDoS



Componente	Descrição
Zumbi	Host comprometido que executa código malicioso
Bot	Malware projetado para infectar um host e se comunicar com o Handler
Botnet	Grupo de zumbis que executam o mesmo bot e são controlados por um Handler
Handler	Servidor mestre de comando e controle para uma Botnet
Botmaster	Responsável pelo desenvolvimento, implantação, manutenção e operação da botnet.

Fonte: elaboração própria (2023).

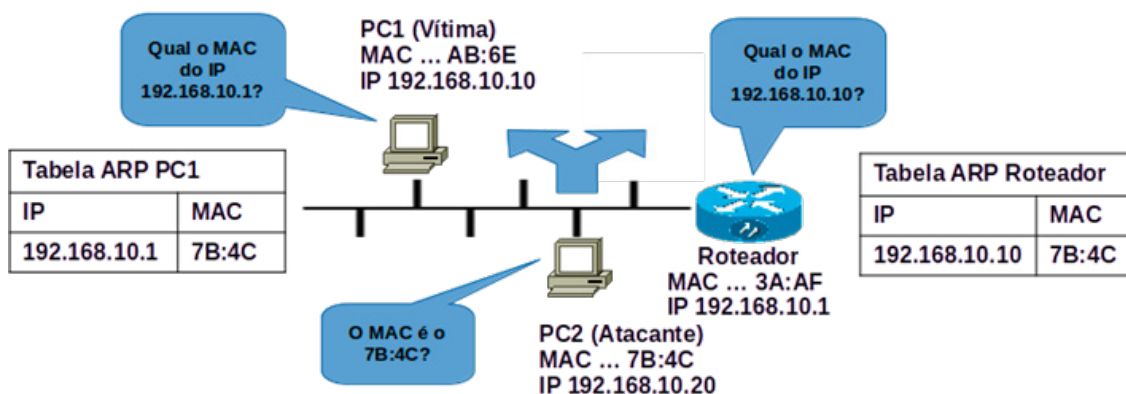
2.2. Ataque de Falsificação (Spoofing)

Neste tipo de ataque, o dispositivo do atacante tenta se passar por outro dispositivo, falsificando os dados utilizados na comunicação.

2.2.1. MAC Spoofing

O dispositivo atacante responde a requisição ARP da vítima com seu próprio MAC, assim todos os frames endereçados a vítima serão endereçados ao atacante também. Outra modalidade seria o atacante responder às requisições ARP tanto à vítima quanto ao default gateway com seu MAC. Nesse caso, toda troca de dados entre a vítima e o default gateway passará pelo atacante, conforme mostrado na figura 2.

Figura 2: ARP Spoofing

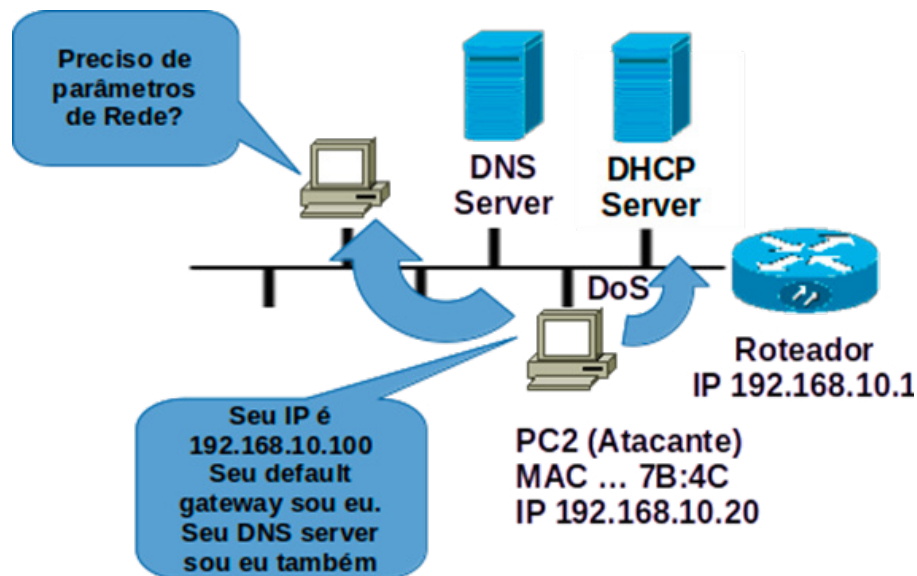


Fonte: elaboração própria (2023).

2.2.2. DHCP Spoofing

Este ataque ocorre quando um servidor DHCP invasor fornece falsos parâmetros de configuração IP aos clientes legítimos, como mostrado na figura 3.

Figura 3: DHCP Spoofing



Fonte: elaboração própria (2023).

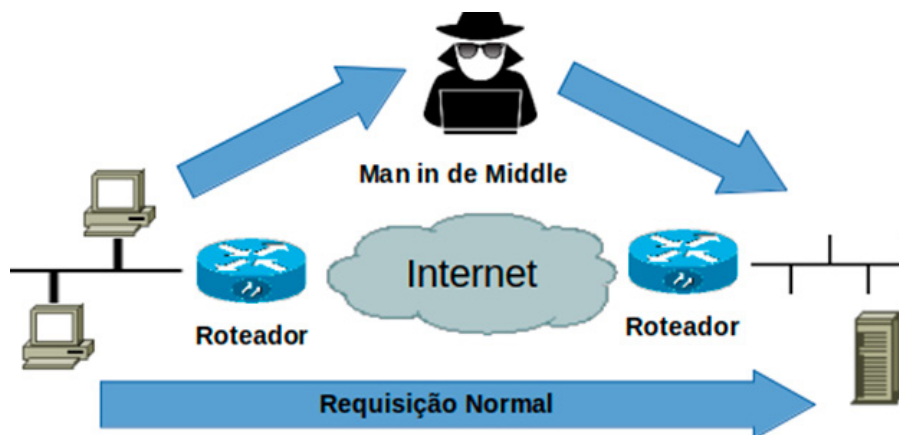
Um servidor não autorizado pode fornecer uma variedade de informações enganosas.

- gateway padrão falso;
- servidor DNS falso;
- endereço IP falso.

2.3. Ataque man-in-the-middle

Em um ataque man-in-the-middle, o atacante se posiciona entre duas partes que tentam se comunicar. Utilizam sites falsos que são acessados ou por phishing ou por ataques DoS nos sites originais ou em servidores DNS. A figura 4 mostra um exemplo de ataque do tipo man-in-the-middle.

Figura 4: Ataque Man in the Middle



Fonte: elaboração própria (2023).

2.4. Estouro de Buffer (Buffer overflow)

O objetivo de um ataque estouro de buffer é encontrar e explorar uma falha relacionada à memória do sistema operacional de um servidor, sobrecarregando-a com valores inesperados, gerando uma exceção, por exemplo, um ator de ameaça insere uma entrada maior do que o esperado pelo aplicativo em execução em um servidor. A resposta do sistema pode ser um acesso ao shell ou um DoS. Um exemplo inicial do uso de pacotes mal formados foi o **Ping of Death**. Nesse ataque, o ator de ameaça envia um ping da morte, que consiste em uma solicitação de eco (ICMP) em um pacote IP maior que o tamanho máximo de pacote de 65.535 bytes. O host receptor não consegue lidar com um pacote desse tamanho e falha.

3. Ataques ao Código da Aplicação

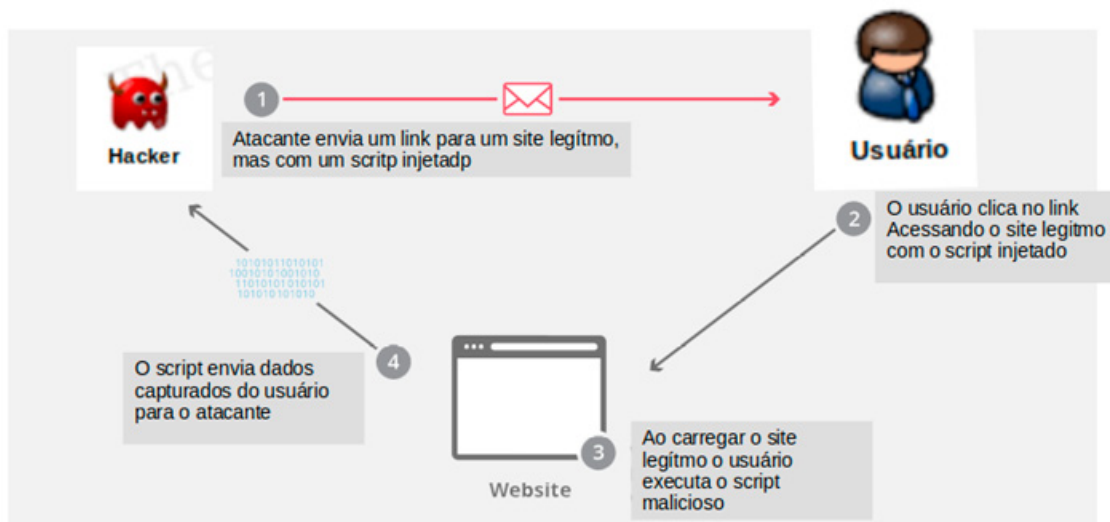
São ataques direcionados a falhas no código da aplicação, proveniente de vulnerabilidade originadas pela não observação de melhores práticas de programação e à não execução de testes de segurança.

3.1. Cross site scripting

Ataques de cross-site scripting (XSS) envolvem código malicioso injetado em sites confiáveis. Ocorre quando os atores de ataques injetam scripts maliciosos no conteúdo do site alvo, que é então entregue ao navegador do usuário. Como o conteúdo dinâmico,

o navegador não tem como saber que os scripts são maliciosos e, portanto, os executa. A figura 5 representa esquematicamente um ataque de cross site scripting:

Figura 5: Cross site scripting

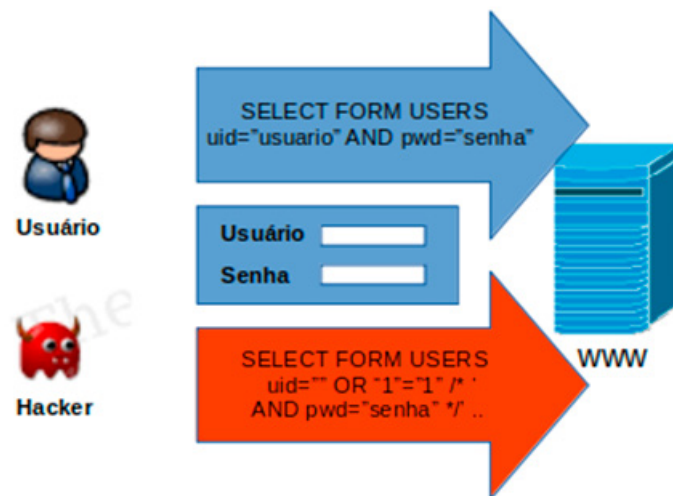


Fonte: elaboração própria (2023).

3.1.1. SQL injection

Um ataque de injeção SQL consiste na inserção ou “injeção” de uma consulta SQL juntamente com os dados de entrada do cliente na aplicação. Esse tipo de ataque bem-sucedido pode ler dados confidenciais do banco de dados, modificá-los ou executar operações de administração no banco de dados. A figura 6 apresenta esquematicamente a dinâmica de um ataque de SQL injection.

Figura 6: SQL Injection



Fonte: elaboração própria (2023).

Na figura, o atacante insere um código malicioso na tela de login do usuário com o objetivo de obter a relação de usuários da aplicação.

4. Ataques de Engenharia Social

Conjunto de técnicas utilizadas para manipular os indivíduos para que realizem ações indevidas (executar um malware) ou obter acesso a informações importantes ou sigilosas (contas e senhas de acesso) por meio da enganação ou exploração da confiança das pessoas, através de persuasão, intimidação, falsificação ou representação. Por exemplo, clientes de um banco recebem um e-mail ou um telefonema falso que alega ser do banco, pedindo a confirmação de seus códigos de acesso. Porém, o método de confirmação não ocorre pelo caminho habitual. As principais técnicas de engenharia social são mostradas no quadro 1.

Quadro 1: Principais técnicas de ataque de engenharia social

Ataques de engenharia social	Descrição
Pretexting	Criação de falsos pretextos, aparentemente positivos, para fazer com que a vítima passe informações confidenciais, por exemplo, sugerindo premiações, indenizações, e heranças de parentes distantes.
Phishing	Um agente de ameaças envia e-mails fraudulentos, disfarçados de fontes legítimas e confiáveis, para induzir o destinatário a instalar malware em seu dispositivo ou compartilhar informações pessoais ou financeiras.
Spear phishing	e-mails e mensagens, que levam a páginas falsas, a fim de coletar informações ou injetar malwares nos dispositivos. No Brasil, sites simulavam a interface da Caixa Econômica, logrando beneficiários do Auxílio Emergencial.
Spam	Também conhecido como lixo eletrônico, este é um e-mail não solicitado que geralmente contém links prejudiciais, malware ou conteúdo enganoso.
Quid Pro Quo (Troca)	Às vezes chamado de Quid pro quo, é quando um ator de ameaça solicita informações pessoais de uma parte em troca de algo como um presente.
Iscas	Um agente de ameaça deixa uma unidade flash infectada por malware em um local público. Uma vítima encontra a unidade e a insere inconscientemente em seu laptop, instalando involuntariamente malware.
Representação	Nesse tipo de ataque, um ator de ameaça finge ser outra pessoa para ganhar a confiança da vítima.
Tailgating	É aqui que um agente de ameaças segue rapidamente uma pessoa autorizada para obter acesso a uma área segura.
Navegação bisbilhoteira	É aqui que o agente de ameaça olha discretamente por cima do ombro de alguém para roubar suas senhas ou outras informações.
Dumpster Diving (Trashing)	É aqui que um ator de ameaças vasculha latas de lixo para descobrir documentos confidenciais.
Vishing	Variação do phishing, porém de forma verbal, por meio de ligações telefônicas.
Sextorsion	Extorsão baseada no vazamento de imagens íntimas, que podem existir ou não.

Fonte: elaboração própria (2023).

5. Métodos de Evasão

Atores de ameaça aprenderam há muito tempo que “esconder é prosperar”. Isso significa que seus métodos de malware e ataque são mais eficazes quando não são detectados. Por essa razão, muitos ataques usam técnicas de evasão furtiva para disfarçar uma carga útil de ataque. Seu objetivo é evitar a detecção, evitando defesas de rede e host. Alguns dos métodos de evasão usados por atores ameaçadores incluem:

Quadro 2: Métodos de evasão usados por atores ameaçadores

Método de Evasão	Descrição
Criptografia e encapsulamento	Essa técnica de evasão usa tunelamento para ocultar, ou criptografia para embaralhar arquivos de malware. Isso torna difícil para muitas técnicas de detecção de segurança detectar e identificar o malware. Tunelamento pode significar ocultar dados roubados dentro de pacotes legítimos.
Fragmentação do tráfego	Essa técnica de evasão divide uma carga maliciosa em pacotes menores para ignorar a detecção de segurança de rede. Depois que os pacotes fragmentados ignoram o sistema de detecção de segurança, o malware é remontado e pode começar a enviar dados confidenciais para fora da rede.
Interpretação errada no nível do protocolo	Essa técnica de evasão ocorre quando as defesas de rede não manipulam corretamente recursos de uma PDU como um valor de soma de verificação ou TTL. Isso pode enganar um firewall para ignorar pacotes que ele deve verificar.
Substituição de tráfego	Nesta técnica de evasão, o ator ameaça tenta enganar um IPS ofuscando os dados na carga útil. Isso é feito codificando-o em um formato diferente. Por exemplo, o ator de ameaça poderia usar tráfego codificado em Unicode em vez de ASCII. O IPS não reconhece o verdadeiro significado dos dados, mas o sistema final de destino pode ler os dados.
Inserção de tráfego	Semelhante à substituição de tráfego, mas o agente de ameaça insere bytes extras de dados em uma sequência maliciosa de dados. As regras do IPS perdem os dados maliciosos, aceitando a sequência completa de dados.
Pivotando	Essa técnica pressupõe que o ator da ameaça comprometeu um host interno e deseja expandir seu acesso ainda mais para a rede comprometida. Um exemplo é um ator de ameaça que obteve acesso à senha de administrador em um host comprometido e está tentando fazer login em outro host usando as mesmas credenciais.
Rootkits	Um rootkit é uma ferramenta agressora complexa usada por atores experientes em ameaças. Ele se integra com os níveis mais baixos do sistema operacional. Quando um programa tenta listar arquivos, processos ou conexões de rede, o rootkit apresenta uma versão higienizada da saída, eliminando qualquer saída incriminadora. O objetivo do rootkit é ocultar completamente as atividades do atacante no sistema local.
Proxies	O tráfego de rede pode ser redirecionado através de sistemas intermediários para ocultar o destino final para dados roubados. Desta forma, comando-e-controle conhecido não pode ser bloqueado por uma empresa porque o destino proxy parece benigno. Além disso, se os dados estiverem sendo roubados, o destino dos dados roubados pode ser distribuído entre muitos proxies, não chamando a atenção para o fato de que um único destino desconhecido está servindo como destino para grandes quantidades de tráfego de rede.

Fonte: elaboração própria (2023).

Novos métodos de ataque estão constantemente sendo desenvolvidos. O pessoal de segurança da rede deve estar ciente dos métodos de ataque mais recentes para detectá-los.

Considerações Finais da Aula

Ataque e vulnerabilidades são uma preocupação constante dos profissionais de cibersegurança. Nesta aula, vimos uma metodologia que podemos aplicar para entender como os ataques são efetuados, os principais tipos de ataques e suas características. Esse conhecimento é fundamental para que possamos projetar uma infraestrutura de segurança, a fim de mitigar os riscos aos quais uma organização está exposta.

Material Complementar



EC-Council – Code of Ethical (código de ética)

Um hacking ético é um profissional de cibersegurança que atua de forma ofensiva em busca de falhas no sistema. Ele atua com a autorização da empresa contratante, simula um ataque cibernético com o objetivo de identificar os pontos de vulnerabilidades, buscando detectar falhas tanto em softwares como nos hardwares. Veja neste site o código de ética proposto pelo EC-Council.

Link para acesso: <https://www.eccouncil.org/code-of-ethics/>

Referências

BARRETO, Jeanine dos Santos *et al.* **Fundamentos de segurança da informação**. Porto Alegre: SAGAH, 2018.

COMER, Douglas E. **Redes de computadores e internet**. 6. ed. Porto Alegre: Bookman, 2016.

EC-COUNCIL. **Code of Ethical**. Disponível em: <https://www.eccouncil.org/code-of-ethics/>. Acesso em: 30 set. 2023.

FOROUZAN, Behrouz A.; MOSHARRAF, Firouz. **Redes de computadores: uma abordagem top-down**. 1. ed. Porto Alegre: AMGH, 2013.

LACERDA, Paulo Sérgio Pádua de *et al.* **Projeto de redes de computadores**. Porto Alegre: SAGAH, 2022.

MAIA, Luiz Paulo. **Arquitetura de redes de computadores**. 2. ed. Rio de Janeiro: LTC, 2013.

MORAES, Alexandre Fernandes de. **Segurança em redes: fundamentos**. São Paulo: Erica, 2010.

NETWORK ACADEMY. *Introduction to Networks (CCNAv7)*. Disponível em: <https://www.netacad.com/>. Acesso em: 3 set. 2023.

SOUSA, Lindeberg Barros de. *Redes de computadores: guia total*. 1. ed. São Paulo: Erica, 2009.

_____. *Administração de redes locais*. 2. ed. São Paulo: Erica, 2020.